

POLÍTICA DE PREVENCIÓN DE PÉRDIDA DE DATOS (DLP)

Versión 1.0

Diego Amorin 4Geeks

Junio 2026

1. Introducción al Data Loss Prevention (DLP)

La Prevención de Pérdida de Datos, conocida por sus siglas en inglés DLP (Data Loss Prevention), es un conjunto de estrategias, procesos y herramientas tecnológicas diseñadas para detectar, monitorear y prevenir la transmisión no autorizada de información confidencial fuera del perímetro de la organización.

En el contexto actual, donde la información constituye uno de los activos más valiosos de cualquier organización, la pérdida o exposición no controlada de datos puede tener consecuencias graves: sanciones regulatorias, daño reputacional, pérdidas económicas y compromisos de seguridad que afecten a clientes, socios y empleados.

1.1 ¿Por qué es importante el DLP?

Las organizaciones gestionan diariamente grandes volúmenes de información sensible: datos financieros, registros de clientes, propiedad intelectual y credenciales de acceso, entre otros. El DLP cumple un papel central en la protección de estos datos a través de tres funciones principales:

- **Prevención:** bloquear o alertar ante intentos de transferir datos sensibles por canales no autorizados (correo electrónico, dispositivos USB, servicios en la nube, etc.).
- **Detección:** identificar comportamientos anómalos o patrones que sugieran una posible filtración, ya sea accidental o maliciosa.
- **Respuesta:** proporcionar evidencia forense y mecanismos de respuesta ante incidentes de seguridad relacionados con la información.

El DLP no es únicamente una solución tecnológica; es también un marco de políticas, procedimientos y concienciación del personal. Una estrategia DLP efectiva combina controles técnicos con una cultura organizacional orientada a la seguridad de la información.

2. Clasificación de Datos

Para aplicar controles proporcionales al valor y sensibilidad de la información, la organización clasifica sus datos en tres categorías. Esta clasificación es la base de todas las decisiones de acceso, almacenamiento, transmisión y eliminación de información.

Categoría	Descripción	Ejemplos
Datos Públicos	Información que puede compartirse libremente sin riesgo para la organización.	Comunicados de prensa, información del sitio web corporativo, ofertas de empleo.
Datos Internos	Información de uso interno cuya divulgación no autorizada podría causar daños menores.	Políticas internas, procedimientos operativos, directorios de empleados.
Datos Sensibles	Información cuya divulgación no autorizada puede causar daño grave a la organización o a personas.	Datos financieros, información de clientes, credenciales de acceso, propiedad intelectual.

2.1 Criterios de clasificación

- La clasificación es responsabilidad del propietario del dato (el área que genera o gestiona la información).
- Ante la duda, se aplicará siempre la categoría más restrictiva hasta que se confirme lo contrario.
- Los datos sensibles deben etiquetarse explícitamente en los documentos, sistemas y repositorios donde se almacenen.
- La clasificación debe revisarse al menos anualmente o cuando cambie la naturaleza del dato.

3. Acceso y Control — Principio del Menor Privilegio

El principio del menor privilegio (Principle of Least Privilege, PoLP) establece que cada usuario, proceso o sistema debe tener acceso únicamente a los recursos e información estrictamente necesarios para desempeñar su función, y durante el tiempo mínimo requerido.

3.1 Políticas de acceso

- Los accesos se otorgan por defecto con el nivel mínimo necesario. Cualquier ampliación debe justificarse formalmente.
- Se prohíbe el uso de cuentas compartidas o genéricas para acceder a datos internos o sensibles.
- Los accesos temporales (proyectos, consultores externos, becarios) deben tener fecha de expiración definida en el momento de su creación.
- El acceso a datos sensibles requiere autenticación multifactor (MFA).
- Los privilegios de administrador están reservados exclusivamente para el personal de TI autorizado y no deben utilizarse como cuenta de uso diario.

3.2 Roles y responsabilidades en la revisión de permisos

Rol	Responsabilidad	Frecuencia de revisión
Administrador de Sistemas (IT)	Otorgar, modificar y revocar permisos técnicos. Gestionar cuentas de usuario y grupos.	Mensual y ante cualquier cambio de rol.
Responsable de Área / Manager	Solicitar y aprobar accesos para su equipo. Notificar bajas o cambios de función.	Trimestral.
Oficial de Seguridad (CISO/ISO)	Auditar que los permisos cumplan el principio de mínimo privilegio. Validar revisiones.	Semestral o ante incidentes.
Recursos Humanos	Informar incorporaciones, cambios de puesto y ceses. Coordinar la revocación inmediata de accesos.	Ante cada evento de RRHH.

3.3 Flujo de revisión de permisos

- Solicitud: el responsable de área envía una solicitud formal al equipo de TI indicando el usuario, recurso solicitado y justificación de negocio.
- Aprobación: el Oficial de Seguridad valida que el acceso sea coherente con el principio de mínimo privilegio.
- Implementación: el Administrador de Sistemas ejecuta el cambio en los sistemas correspondientes.
- Documentación: el cambio queda registrado en el sistema de gestión de identidades (IAM) con fecha, responsable y justificación.
- Revisión periódica: según la frecuencia indicada en la tabla anterior, se auditan los accesos activos y se revocan los que ya no sean necesarios.

4. Monitoreo y Auditoría

El monitoreo continuo y la auditoría periódica son componentes esenciales de una estrategia DLP efectiva. Permiten detectar actividades anómalas, verificar el cumplimiento de las políticas y generar evidencia forense ante incidentes.

4.1 Reglas de monitoreo

- Todo acceso, modificación, copia o eliminación de datos clasificados como Sensibles queda registrado en el sistema de logs.
- Las transferencias de archivos sensibles hacia dispositivos externos, correo electrónico o servicios en la nube son monitoreadas en tiempo real.
- Los intentos de acceso no autorizado generan alertas automáticas que se escalan al Oficial de Seguridad en un plazo máximo de 15 minutos.
- Se monitorea el volumen inusual de descargas o copias de datos (exfiltración masiva).

4.2 Herramientas de monitoreo y auditoría

La organización utilizará las siguientes categorías de herramientas para implementar el monitoreo:

- SIEM (Security Information and Event Management): centraliza y correlaciona logs de todos los sistemas. Ejemplos representativos del mercado: Splunk, Microsoft Sentinel, IBM QRadar. Permite detectar patrones de comportamiento anómalo y generar alertas en tiempo real.
- Solución DLP de endpoint: controla el uso de datos en los dispositivos de los usuarios (USB, impresión, captura de pantalla, transferencia de archivos). Ejemplos representativos: Symantec DLP, Forcepoint DLP, Microsoft Purview.
- DLP de red: inspecciona el tráfico de red para detectar transferencias de datos sensibles por canales no autorizados (correo, web, FTP).

- Gestión de Identidades y Accesos (IAM): registra todos los cambios de permisos y accesos. Ejemplos representativos: Microsoft Active Directory, Okta.

4.3 Auditorías

- Se realizarán auditorías internas de accesos y permisos con la frecuencia indicada en la sección 3.
- Al menos una vez al año se contratará una auditoría externa independiente que evalúe la efectividad de los controles DLP.
- Los registros de auditoría se conservarán durante un mínimo de 12 meses en almacenamiento seguro con integridad verificable.

5. Prevención de Filtraciones

La prevención de filtraciones abarca el conjunto de controles técnicos y procedimentales que minimizan la probabilidad de que datos sensibles salgan del entorno controlado de la organización, ya sea de forma accidental o intencionada.

5.1 Cifrado

- Todos los datos sensibles deben almacenarse cifrados en reposo, utilizando estándares actuales (AES-256 o equivalente).
- La transmisión de datos sensibles debe realizarse exclusivamente a través de canales cifrados (TLS 1.2 o superior, VPN corporativa).
- Los dispositivos portátiles (laptops, discos externos autorizados) que puedan contener datos sensibles deben contar con cifrado de disco completo.
- Las claves de cifrado se gestionan de forma centralizada y su acceso está restringido al personal autorizado de TI.

5.2 Controles de exfiltración

- Se restringe el uso de dispositivos de almacenamiento externo (USB, discos externos) mediante políticas de grupo (GPO) en los equipos corporativos. Las excepciones deben ser aprobadas por el Oficial de Seguridad.
- El envío de datos sensibles por correo electrónico a direcciones externas está bloqueado por defecto. Requiere autorización explícita y registro.
- La carga de datos sensibles a servicios de almacenamiento en la nube no corporativos (Google Drive personal, Dropbox, WeTransfer, etc.) está prohibida y bloqueada técnicamente.
- Se aplica inspección de contenido (Content Inspection) en el gateway de correo y en la solución DLP de red para detectar datos sensibles en tránsito.

5.3 Gestión de incidentes

- Cualquier sospecha de fuga de datos debe reportarse inmediatamente al Oficial de Seguridad y al responsable del área afectada.
- Se activará el protocolo de respuesta a incidentes, que incluye contención, análisis forense, notificación y remediación.
- Si la filtración afecta a datos personales, se evaluará la obligación de notificación a las autoridades competentes según la normativa aplicable.

6. Educación y Concientización

La tecnología por sí sola no es suficiente para prevenir la pérdida de datos. El factor humano es frecuentemente el eslabón más vulnerable en la cadena de seguridad, por lo que la educación y la concienciación del personal son componentes críticos de esta política.

6.1 Programa de capacitación

- Inducción obligatoria: todo empleado nuevo recibirá formación sobre esta política DLP antes de acceder a sistemas corporativos. El contenido incluirá clasificación de datos, uso aceptable de dispositivos y canales, y procedimientos de reporte de incidentes.
- Capacitación anual: todos los empleados completarán un módulo de actualización en seguridad de la información al menos una vez al año.
- Capacitación específica por rol: el personal con acceso a datos sensibles (finanzas, RRHH, desarrollo, dirección) recibirá formación adicional adaptada a los riesgos de su función.
- Simulaciones de phishing: se realizarán pruebas periódicas de ingeniería social para evaluar el nivel de concienciación y reforzar los comportamientos seguros.

6.2 Canales de comunicación

- Se mantendrá un repositorio interno accesible con la política actualizada, guías de uso aceptable y preguntas frecuentes sobre seguridad.
- Se difundirán recordatorios periódicos (boletines, alertas internas) sobre buenas prácticas y amenazas recientes relevantes para la organización.
- Existirá un canal confidencial para que los empleados reporten comportamientos sospechosos o dudas sobre el manejo de datos sin temor a represalias.

6.3 Evaluación de la efectividad

- Se medirá el porcentaje de empleados que completan la capacitación anual (objetivo: 100%).
- Se analizarán los resultados de las simulaciones de phishing para identificar áreas de mejora.
- El número y tipo de incidentes relacionados con el factor humano se revisará trimestralmente para ajustar el programa formativo.

Esta política entra en vigor en la fecha de su aprobación y será revisada anualmente o ante cambios significativos en el entorno tecnológico o normativo de la organización.

Política de Prevención de Pérdida de Datos (DLP)